

SOC275 - Application Token Steal Attempt Detected

04 February 2026 15:24

SEVERITY	DATE	RULE NAME	EVENTID	TYPE	ACTION
Medium	Apr, 19, 2024, 08:23 AM	SOC275 - Application Token Steal Attempt Detected	250	Proxy	>> ✓
EventID : 250 Event Time : Apr, 19, 2024, 08:23 AM Rule : SOC275 - Application Token Steal Attempt Detected Level : Security Analyst Hostname : Gloriana IP Address : 172.16.17.172 Affected User : gloriana@letsdefend.io Trigger Request : GET /reset-password?email=gloriana@letsdefend.io HTTP/1.1 Trigger Reason : Detect potential application token theft attempts by monitoring web server access logs for GET or POST requests to password reset or account recovery pages, checking for the presence of HTTP request headers like 'Authorization' or 'Bearer', and targeting URLs associated with application tokens. Device Action : Redirect					

Incident Overview

- **Alert Type:** Web Application
- **Severity:** Medium
- **Environment:** Password reset page on Web Application

Initial Alert Details

A HTTP GET request targeting application password reset page was observed for a specific user gloriana@letsdefend.io, originating from the endpoint named Gloriana(172.16.17.172)

Analyst Thought Process (Before Investigation)

- Password reset page access was observed and the security control intervened to redirect the request to contain risk.
- The access can either be a benign attempt from the user or an attacker trying to compromise credentials for unauthorized access.
- Immediate action is to validate the request is benign or suspicious through confirmation from user and log analysis.

Investigation Findings

- The user accessed the password reset URL from the Phishing email sent impersonating as Discord Password Reset.
- But upon closer Investigation, the IP and domain hosting the password page are of highly suspicious.
- A POST request is observed with cleartext tokens in it confirming token abuse.

IOC Artifacts

Type of IOC	Context	IOC Value	Threat Intel
IP Addres	Password Reset Hosting IP	23.82.12.29	Flagged as Malicious Associated with Phishing

s			
Domain	Password Reset Hosting page	homespottersf.com	Flagged as Malicious Associated with Phishing
URL	Password Reset URL from email	hxxp://homespottersf.com:8081/reset-password?token=123letsdefendisthebest123	Flagged as Malicious Associated with Phishing

Attack Chain Summary

External attacker

- Phishing Email
- Password Reset Endpoint
- Clear Text token POST Request
- Fake Reset Credential Page

SOC Actions & Recommendations

- Immediately Escalate to L2
- Block the IOC artifacts involved
- Reset the credentials if user had reset the password through that fake login page.
- Train users for awareness of Phishing emails.

Key Learnings

- Email headers can be manipulated to impersonate as legit communication.
- Early detection of these type of attacks can prevent account takeovers.